

Bachelor's Thesis Proposal

Static Analysis for Personal Data

Assessor: Dr. Hoang Nguyen

Co-assessor: To be decided

1 Motivation

Ensuring that software systems, especially web applications, comply with privacy requirements is a complex and critical challenge. On the one hand, it is complex because laws, such as the GDPR [1], impose strict requirements on how organizations handle (personal) data but offer limited guidance on concrete technical solutions. On the other hand, it is critical because failing to comply with these requirements can result in substantial financial penalties.

When analyzing a software system, it is important to know precisely *where* personal data resides and *how* it flows through the system. For the large body of existing applications, this information is not documented but is embedded implicitly in the source code. Locating personal data manually across a codebase is tedious, error-prone, and does not scale, which makes automated support highly desirable.

2 Objective

The objective of this thesis is to develop an automated *code scanning* approach that statically analyzes a source codebase to identify personal data: where it is collected, stored, and processed. Within the scope of the thesis, we restrict the scanner to a subset of a general-purpose programming language (e.g., Python).

The scanner should recognize different categories of personal data (e.g., identifiers, contact details, and special categories of data) and, where feasible, track the flow of such data from its collection points to relevant sinks (persistence, logging, and transmission to third parties).

3 Tasks

1. Study the GDPR notion of personal data and review existing static analysis and taint analysis techniques for detecting sensitive or personal data in source code.
2. Design a code scanning approach that locates personal data declarations and tracks their flow to the relevant sinks.
3. Implement the scanner for a chosen programming language or web framework.
4. Validate the scanner on a set of open-source applications.
5. Document the design, implementation, and evaluation in the final report.

4 Deliverables

The following deliverables are due at the end of the project:

Final report Please have a look at the submission requirements in the following section. The final report should consist of an introduction, a (theoretical) background section, sections describing the work packages and their outcomes, and a conclusion. The report must be written in English.

Source code Complete, documented source code with a reproducible evaluation.

Presentation At the end of the thesis, a 20-minute presentation must be given in a thesis defense seminar. It should give an overview and discuss the most important highlights of the work.

References

- [1] European Parliament and Council. Regulation (EU) 2016/679, 2016. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.